

Third-Party Vendor Attack · POS Malware · 40 Million Cards Stolen

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** No CVE — social engineering entry via HVAC vendor. Research CISA Alert AA18-336A.

INCIDENT OVERVIEW

In November–December 2013, attackers compromised retail giant Target Corporation through a third-party HVAC vendor, Fazio Mechanical Services. By stealing the vendor's network credentials through a phishing email, attackers moved into Target's corporate network, deployed point-of-sale (POS) malware called BlackPOS, and over 19 days silently exfiltrated the credit and debit card data of 40 million customers plus personal information of 70 million additional customers. Target's own FireEye security system fired alerts — and the security team ignored them. The breach cost Target over \$292 million and the CEO resigned.

KEY FACTS AT A GLANCE

- 40 million credit/debit card numbers stolen + 70 million personal records exposed
- Entry point: Phishing email to HVAC vendor Fazio Mechanical — stole their VPN credentials
- Attack duration: 19 days of active exfiltration before shutdown
- FireEye alerts fired and were IGNORED by Target's security operations team
- Malware: BlackPOS (also called Kaptoxa) — scraped card data from POS terminal memory
- Cost to Target: \$292 million in settlements, expenses, and remediation
- CEO Gregg Steinhafel resigned in May 2014

🎯 **OBJECTIVE:** Students understand the Target Data Breach at a high level and apply the CIA Triad to identify which pillars were violated and how.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:15	Welcome & Project Overview	Distribute Project 1 packet. Explain: this project is about understanding exactly what happened. Next project we apply frameworks and write the executive summary.
0:15-0:45	Lecture: CIA Triad	Teach Confidentiality, Integrity, Availability. Use real-world examples. Ask: what happens when each one fails?
0:45-1:10	Read the Incident	Students read the Incident Overview (15 min silent). Then open discussion: What happened? What was your first reaction?
1:10-1:50	CIA Triad Mapping Activity	Students fill out their CIA Triad worksheet — which pillars were violated, specific evidence, impact rating (Low/Med/High/Critical).
1:50-2:00	Debrief & Homework	Share out. Homework: Write a 1-paragraph plain-English explanation of the incident for a non-technical reader.

🎯 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: Kill Chain	Teach the 7 phases. For each: what does the attacker do? At what point could a defender have stopped this?
0:30-1:00	Demo: Phase Walkthrough	Walk through ONE Kill Chain phase together as a class. Model your analysis process out loud.
1:00-1:45	Kill Chain Mapping	Students complete the full Kill Chain table — all 7 phases with specific incident evidence, not generic descriptions.
1:45-2:00	Discussion	Which phase was the most preventable? Which phase was most surprising? What would have stopped the attack?

🔗 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: MITRE ATT&CK	Explain Tactics (the WHY), Techniques (the HOW), Procedures (the specific implementation). Show the ATT&CK Navigator.
0:30-0:50	Live Demo: attack.mitre.org	Navigate the matrix together. Look up ONE technique from this incident. Show the description, procedure examples, and detection methods.
0:50-1:40	ATT&CK Research Lab	Students identify 3-5 techniques from the incident. For each: ID, name, tactic, and plain-English explanation.
1:40-2:00	Class ATT&CK Heat Map	Build a shared map on the board. Students add techniques. What does the pattern tell us about where to focus defenses?

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	CVE Orientation	Walk students through nvd.nist.gov and cisa.gov . Show them how to read a CVE entry: description, CVSS score, references.
0:20-1:10	Research Lab + Worksheet	Students research: CISA Alert AA18-336A (POS Malware), USSS/FBI BlackPOS Flash Report, PCI DSS. Document: patch/fix, when available, how the incident was contained, who was involved.
1:10-1:40	Timeline + Finalization	
1:40-2:00	Submit + Next Project Preview	Students submit completed CVE Research Worksheet (50 points). Open discussion: What surprised you? Preview next project: NIST CSF, attacker methodology, and Executive Summary.

KILL CHAIN REFERENCE — FULL ANALYSIS

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
1. Reconnaissance	Attackers identified Fazio Mechanical as a Target vendor with network access online	Threat intelligence; dark web monitoring; monitor vendor relationships
2. Weaponization	Created phishing email with malware designed to steal Fazio employee credentials	Patch management; secure development practices; code signing
3. Delivery	Phishing email sent to Fazio employees — at least one employee clicked and credentials were stolen	Email filtering; MFA; user security awareness training
4. Exploitation	Used stolen Fazio VPN credentials to log into Target's Ariba vendor portal, then pivoted inward	Patch known CVEs; WAF; regular penetration testing
5. Installation	Deployed BlackPOS malware on ~1,800 Target POS terminals across stores	File integrity monitoring; application whitelisting; EDR
6. Command & Control	Staged stolen card data on internal FTP servers then exfiltrated to external servers in Eastern Europe	DNS filtering; SSL inspection; anomaly detection on outbound traffic
7. Actions on Obj.	Exfiltrated 40M card records + 70M personal records over 19 days — data sold on black market	Data loss prevention (DLP); database activity monitoring; network segmentation

MITRE ATT&CK TECHNIQUE REFERENCE

TECHNIQUE ID	TECHNIQUE NAME	HOW IT WAS USED
T1566	Phishing	Sent phishing email to Fazio Mechanical employee to steal VPN credentials
T1078	Valid Accounts	Used stolen Fazio credentials to authenticate into Target's vendor portal
T1071	Application Layer Protocol	Used standard HTTP/FTP for C2 to blend with normal business traffic
T1041	Exfiltration Over C2 Channel	Exfiltrated card data through the established C2 infrastructure to Eastern Europe
T1078.003	Local Accounts	Created local admin accounts on POS systems for persistence

CVE / ADVISORY REFERENCE

 **IDENTIFIER:** No CVE — social engineering entry via HVAC vendor. Research CISA Alert AA18-336A.

HOW IT WAS PATCHED

- No software patch — this was a process failure, not a software vulnerability
- BlackPOS malware removed from approximately 1,800 POS terminals
- Exfiltration FTP servers in Eastern Europe and Brazil taken offline with law enforcement cooperation
- Target completely re-segmented their network — POS systems now fully isolated
- Vendor access controls redesigned: no vendor gets broad network access anymore
- FireEye alert process overhauled — all alerts require mandatory human review with SLA

HOW THE INCIDENT WAS CONTAINED

- U.S. Secret Service and FBI launched investigation; Mandiant hired for forensics
- Credit card networks flagged and blocked the compromised card numbers
- Target worked with banks to reissue approximately 40 million payment cards
- Target offered 1 year free credit monitoring to all 70+ million affected customers

INCIDENT TIMELINE

DATE	EVENT
Nov 12, 2013	Attacker gains access via stolen Fazio VPN credentials
Nov 27, 2013	BlackPOS deployed to POS terminals — timed to Black Friday shopping rush
Nov 30, 2013	FireEye alerts begin firing — security team does NOT act
Dec 12, 2013	Department of Justice notifies Target of the breach
Dec 15, 2013	Target shuts down exfiltration servers — breach contained
Dec 19, 2013	Target publicly discloses the breach
May 2014	CEO Gregg Steinhafel resigns
2017	\$18.5M multi-state attorney general settlement finalized

PROJECT 1 ASSESSMENT — CVE RESEARCH WORKSHEET (50 POINTS)

 **DUE:** Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- U.S. Senate Commerce Committee: "A Kill Chain Analysis of the 2013 Target Data Breach" (2014)
- Krebs on Security: "Target Hackers Broke in Via HVAC Company" — krebsonsecurity.com
- CISA Alert AA18-336A: Point-of-Sale Malware — cisa.gov
- MITRE ATT&CK: attack.mitre.org — search T1566, T1078, T1041
- NIST Cybersecurity Framework: nist.gov/cyberframework
- PCI Security Standards: pcisecuritystandards.org